

Gerenciamento Continuidade de Negócios



Gestão de Continuidade de Negócios

A gestão de continuidade de negócios é processo de gerenciamento holístico que visa identificar ameaças potenciais a uma organização e os impactos nas operações de negócios que essas ameaças, se concretizadas, podem causar, podendo ainda ser conceituada como uma estrutura para identificar a exposição a riscos de uma organização a diversos tipos de ameaças internas e externas.

A gestão de continuidade de negócios possibilita a criação de uma estrutura que permite a organização construir uma resiliência operacional para garantir a proteção e salvaguarda dos interesses da organização e de sua alta administração e faz parte integrante de outras disciplinas tais como: a gestão de resposta a incidentes; gestão de crises, gestão de recuperação de desastres de TI e da própria continuidade de negócios, fornecendo à organização a capacidade de responder de forma efetiva diversos tipos de ameaças tais como: (a) desastres naturais; (b) violação de dados; © ataques de negação de serviço realizados por hackers; (d) vazamento de dados pessoais; (e) indisponibilidade de serviços ou recursos de TI; (f) proteção dos interesses comerciais da empresa; dentre outros.

Uma boa gestão de continuidade de negócios deve possuir processos que permitam a recuperação de desastres que impossibilitem a organização de realizar a entrega de sua proposta de valor e a realização do seu modelo de negócio, bem como outros itens, dos quais destacam-se: (a) o gerenciamento de crises; (b) o gerenciamento de incidentes; © o gerenciamento de emergências e por fim (d) o planejamento de contingência.

De acordo com a ISO 22301, um sistema de gestão de continuidade de negócios enfatiza a importância de: (a) compreender as necessidades de continuidade e preparação, bem como a necessidade de estabelecer políticas e objetivos relacionados à gestão de continuidade de negócios; (b) a implementação e operacionalização de ações, controles e medidas que possibilitem o gerenciamento

dos riscos; © o monitoramento e revisão das métricas relacionadas a desempenho e eficácia do sistema de gestão de continuidade de negócios e, por fim (d) a melhoria contínua com base no planejamento estratégico da organização e as medições do sistema de gestão de continuidade de negócios.

Diante do contexto apresentado, podemos perceber que a gestão da continuidade de negócios deve abraçar toda a organização, incluindo os processos realizados pelas áreas de negócios, colaboradores, fornecedores, parceiros comerciais, garantindo assim que mesmo acontecendo um desastre de qualquer tipo a organização irá continuar a realizar o seu modelo de negócio, entregando a sua proposta de valor a seus clientes e ao mercado que atua.

Existem diversas razões para se ter um sistema de gestão de continuidade de negócios robusto, dentre as quais destacam-se: (a) a conformidade legal e regulamentar que a organização está sujeita; (b) as demandas da organização por seus fornecedores e clientes; © maximização do modelo de negócio; (d) a gestão de marca e reputação perante ao mercado e seus clientes; (e) a garantia da resiliência do modelo de negócio e da própria organização.

Continuidade de Negócios TI

A continuidade de negócio de TI é uma abordagem holística utilizada pelas equipes de segurança da informação e segurança cibernética de uma organização para gerenciar todos os ativos de TI no caso de um problema grande relacionado a interrupção, falha ou indisponibilidade.

A continuidade de negócios em TI é um processo essencial que visa capacitar as equipes de TI e a organização a responder em momentos de crises decorrentes da continuidade de negócios através da implementação de mecanismos capazes de responder à recuperação de desastres e failover. Neste contexto, é preciso que a organização implemente um conjunto de políticas e procedimentos através de um plano de continuidade que garantam que todos os envolvidos neste plano saibam o que fazer no caso de um momento de crise.

Plano de Continuidade de Negócios TI

No geral, um plano de continuidade de negócios em TI, concentra-se na criação de estratégias capazes de sustentar todos os pontos e processos críticos de TI de uma

organização, para o caso de qualquer tipo de interrupção, fornecendo orientações detalhadas a todos, sobre as ações e procedimentos necessários para garantir as operações de TI, durante e após um grande incidente não planejado. Ou seja, durante um momento de crise que afete os serviços e recursos críticos de TI.

Com relação ao planejamento de contingência de TI, este por sua vez refere-se a criação de planos, políticas, procedimento e medidas técnicas que permitam a recuperação das operações de TI, após um incidente inesperado, que por sua vez pode ser um evento disruptivo que se não tratado pode levar a um grande desastre. É importante ressaltar que toda e qualquer organização deve possuir pelo menos um plano de contingência de TI, para responder a uma série de eventos e/ou incidentes inesperados e não desejados tais como: (a) eventos ou incidentes de causas naturais – inundação, terremoto, maremoto, etc.; (b) eventos ou incidentes ocasionados por falhas tecnológicas – bugs de sistema, códigos maliciosos, vírus de computador, falhas ou pane elétrico, incêndio, etc. © eventos ou incidentes ocasionados por fator humano de forma não intencional – erros operacionais, falta de conhecimento ou treinamento e, por fim (d) eventos ou incidentes ocasionados por fator humano de forma intencional – ataques hackers ou terroristas, invasão de sistemas, vazamento ou roubo de dados ou informação, etc.

Lembre-se: não podemos esperar que os sistemas computacionais funcionem sempre perfeitamente. Em algum momento eles irão falhar, o que tornará seus serviços e recursos indisponíveis a qualquer um que precise utilizá-los. Por este motivo é que se faz necessário um plano de contingência de TI e um plano de continuidade de negócios.

Por fim, com relação ao conteúdo, duração e recursos necessários para a criação de um plano de contingência de TI e um plano de continuidade de negócios, estes podem variar dependendo do tamanho e da sofisticação das operações de TI que suportam o modelo de negócio e toda a organização. Já com relação a organizações de grande porte, poderá haver um conjunto de planos que irão compor toda a contingência e continuidade da TI e do próprio modelo de negócio e, poderão receber diversas nomenclaturas, tais como: (a) gerenciamento e contingência de TI; (b) gerenciamento de respostas a incidentes de TI; © gestão de desastre e recuperação de TI; (d) plano de resposta a incidentes de TI e assim por diante. Mas, lembre-se, todos no geral possuem o mesmo propósito, que é o de garantir a continuidade dos negócios e a contingência das operações de TI.

Plano de Recuperação de Desastres de TI

O plano de recuperação de desastres, também conhecido como DRP é um plano criado pela área de segurança da informação ou segurança cibernética que tem como objetivo implementar um conjunto de políticas, normas, ações e procedimentos destinados a auxiliar na execução de processos de recuperação em resposta a um desastre, visando proteger toda a infraestrutura de TI necessária a operação do modelo de negócio de uma organização, promovendo assim a recuperação dos ativos de TI e respectivamente os recursos e serviços críticos que sustentam o negócio da organização.

Em geral, o DRP deve explicar de forma abrangente as ações consistentes que devem ser realizadas antes, durante e depois da ocorrência de qualquer tipo de evento ou incidente não planejado que seja classificado como um desastre, proporcionando assim que todas as equipes de TI saibam e possam realizar todas as ações de maneira coordenada e de forma eficiente e eficaz. É importante lembrar que um DRP deve abordar todo e qualquer tipo de desastre, seja esse causado por elementos naturais, artificiais, tecnológicos ou humanos.

Seja qual for o tipo e tamanho da organização, no geral, atualmente todas realizam o tratamento de grandes quantidades de dados e utilizam diversos recursos providos pela TI. Neste contexto, iremos encontrar diversos tipos de dados e recursos que serão considerados de missão crítica para o modelo de negócio e toda a organização. Isto significa que qualquer tipo de falha ou interrupção nesses recursos de missão crítica, irão causar um impacto enorme nas operações da organização. Por tanto, a necessidade de se ter um plano de recuperação de desastres torna-se essencial e primordial para a organização.

A criação de um plano de recuperação de desastres de TI, torna-se mais eficaz se realizada em conjunto com outros planos, como por exemplo o plano de contingência de TI, o plano de continuidade de operações, o plano de gerenciamento de incidentes e o plano de continuidade de negócios e, durante a sua fase de construção é importante que se faça uma boa análise de impacto das operações de TI em relação ao negócio. Isto proporcionará às equipes de TI o reconhecimento dos recursos e operações de TI críticos ao modelo de negócio, bem como a categorização de prioridades e o tempo de recuperação.

Como fonte de planejamento as equipes de TI devem pensar e planejar estratégias de recuperação que possibilitem: (a) recuperação de aplicativos e/ou sistemas de informação; (b) recuperação de links de comunicação e/ou a rede; © recuperação de dados e bancos de dados; (e) recuperação de dispositivos de hardware; (f) recuperação de dispositivos computacionais tais como: servidores, storages de armazenamento de dados, switches, roteadores, sistemas de firewall, gateway de comunicação, estações de trabalho consideradas de missão crítica, etc.

Outro ponto importante a saber sobre a criação de um DRP é que cada plano será único e exclusivo, não existirá uma única maneira correta de se construir um plano de recuperação de desastres. No entanto, existem três objetivos principais que qualquer plano de recuperação de desastres deve possuir e que são considerados a base central do plano. São eles: (a) prevenção – deve incluir todas as metodologias, técnicas, ferramentas e mecanismos necessários a promover a prevenção do incidente ou desastre; (b) detecção – deve incluir todas as metodologias, técnicas, ferramentas, ações, procedimentos e mecanismos capazes de detectar novas ameaças potenciais que podem causar um incidente ou desastre e, por fim © correção – deve incluir todas as metodologias, técnicas, ferramentas, ações, procedimentos e mecanismos necessários a correção do incidente e/ou desastre no menor tempo possível e cabe aqui a inclusão do item “lições aprendidas” para garantir a melhoria contínua do plano.

Além da prevenção, detecção e correção, um plano de recuperação de desastres deve também conter outros elementos tais como:

(a) metas – que irão descrever as metas que a organização deseja alcançar durante ou após um desastre, incluindo o objetivo do tempo de recuperação (RTO) e o objetivo do ponto de recuperação (RPO). O primeiro (RTO) refere-se ao tempo de inatividade aceitável após uma interrupção antes que os processos e sistemas de negócio sejam restaurados para operação. Por exemplo, a organização deve poder retornar às operações dentro de 2 horas para evitar impactos inaceitáveis na continuidade dos negócios. Já o segundo (RPO) refere-se à quantidade de dados e/ou informações que a empresa está disposta a perder após a ocorrência de um desastre. Por exemplo, um RPO pode perder no máximo 50 minutos de dados ou informações, o que significa que os backups (cópias de segurança) devem ocorrer pelo menos a cada 50 minutos para alcançar o objetivo do RPO.

(b) Equipes Envolvidas – um plano de recuperação de desastres deve detalhar/especificar as pessoas envolvidas e responsáveis pela execução do plano. Além de garantir que haja um backup, caso aconteça alguma indisponibilidade da pessoa envolvida.

© Inventário de TI – o plano deve conter todo o inventário relacionado a hardware e software que a organização possui e utiliza e, este deve ser mantido devidamente atualizado. É importante neste inventário incluirmos também os serviços e recursos providos pela TI e que sustentam o modelo de negócio, como por exemplo os serviços/recursos de nuvem. Não se deve deixar nada de fora. Ou seja, além de inventariar os itens críticos de TI, deve-se também fazer o inventário dos não críticos.

(d) Procedimento de Backup/Restore – o plano deve estabelecer todos os procedimentos relacionados a criação de cópias de segurança (backups) dos recursos de TI, incluindo os dados. Esse procedimento deve ser detalhado e deve conter informações como: (a) origem da cópia; (b) destino da restauração; © dispositivos computacionais que fazem parte do procedimento do backup; (d) periodicidade do backup; (e) tipo/formato do backup, exemplos: backup completo, incremental, diferencial, espelhado, local, externo, remoto ou em nuvem; (f) procedimento de restauração e, qualquer outra informação que se julgue necessária a execução do backup; (g) testes de recuperação (restore) de backups; (h) período de retenção das mídias de backup;

(e) Procedimento de Recuperação de Desastre – o plano deve conter todo o procedimento e ações necessárias e específicas para garantir a recuperação das operações de TI, incluindo o detalhamento de todas as respostas de emergência, procedimentos e ações de mitigação, limitação de dados e erradicação de ameaças à segurança da informação e segurança cibernética;

(f) Procedimentos de Restauração – o plano deve conter todas as recomendações, procedimentos, ações e práticas para garantir que o próprio plano de recuperação de desastres ocorra de forma eficiente e eficaz, incluindo os procedimentos de restauração detalhados para a recuperação por completo das operações de TI afetadas. É importante dizer que além dos itens mencionados, deve-se também incluir os RPOs, RTOs e SLAs ^[1] existentes.

Por fim, como resultado de um bom plano de recuperação de desastres a organização alcança: (a) relação custo-benefício; (b) aumento da produtividade; © melhora na incorporação ou retenção de clientes e mercado; (d) conformidade; (e) escalabilidade; (f) segurança; (g) confiança perante ao mercado e clientes; (h) credibilidade, dentre outros.

Conteúdo Bônus

Compreenda melhor a importância de um bom plano de gerenciamento de desastres, conhecendo o caso da RENNER.

- O site da Renner sai do ar após ataque hacker – entenda o caso.

Artigo da CNN Brasil.

- Lojas Renner sai do ar após infecção com ransomware.

Artigo da TechMundo.

Referência Bibliográfica

FONTES, E. **Praticando a segurança da informação**. – 2ªEd. Rio de Janeiro. Brasport, 2008.

HARRIS, Shon. **CISSP All-in-one, 3. ed.** Nova York, McGraw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação**. Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas. 2.ed.** São Paulo; Elsevier, 2017.

ASSI, Marcos. Governança, **Risco e Compliance: Mudando a conduta nos negócios – Edição Padrão**, São Paulo Saint Paut, 2017.

FERNANDES, Aguinaldo Aragon. ABREU, Vladimir Ferraz. **Implementando a Governança de TI: da estratégia à gestão dos processos e serviços – 4ª Ed.** Brasport – Rio de Janeiro 2014.

[1]

SLA ou Service-level Agreement (Acordo de Nível de Serviço) trata-se de um acordo/contrato estabelecido entre ambas as partes para garantir o compromisso do serviço prestado de uma parte para a outra.